

ShieldDome 安全设计说明书

1. 信任边界

邮件正文、HTML、附件、RAG 导入文件和 LLM 返回均视为不可信数据。系统不执行邮件中的指令，不运行附件，不将 HTML 直接写入页面 `innerHTML`。

2. 密钥管理

- Key 仅存放于 `/etc/shielddome/shielddome.env`，权限 `600`。
- Web 与 API 只返回脱敏状态。
- 已在聊天中暴露的硅基流动 Key 必须撤销。
- 管理 Token 与邮件接入 Token 分离并定期轮换。

3. 隐私与数据最小化

- 原始邮件使用 AES-GCM 加密落盘并默认在 72 小时后删除；生产环境必须配置 `SHIELDDOME\_DATA\_ENCRYPTION\_KEY`。
- LLM 仅接收脱敏后的正文、域名、附件类型和检测证据。
- 原始附件不发送给 LLM；外部杀毒服务启用前需完成供应商合规评估。
- 检测报告不包含 API Key、密码或附件二进制内容。

4. 应用安全

- Nginx 提供 TLS、限流、50 MB 上限、CSP、X-Frame-Options 和 MIME 嗅探防护。
- 管理员密码使用 scrypt 加盐哈希；连续失败 5 次锁定 15 分钟；登录会话使用随机令牌、服务端摘要存储、过期和主动撤销。
- API 使用 Pydantic 校验；网页使用登录会话，服务间调用使用独立 Token 鉴权。
- URL 重定向主动访问尚未默认启用；启用时必须阻止回环、内网和保留地址以防 SSRF。
- RAG 知识必须人工审核后发布，防止攻击者通过误报反馈污染知识库。

5. 审计

分析创建和完成、知识导入与发布、策略修改和反馈均写入 `audit\_logs`。生产上线应将审计日志同步到独立日志平台，避免单机管理员篡改。

6. 已接受风险

- 单服务器部署无法提供高可用、故障自动切换和无中断升级。

- 本地高权限身份未启用 MFA，不满足完整企业身份安全基线。
- API Token 方案适合首版内部部署，后续应升级为 OIDC/SSO、RBAC 与 MFA。